



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



LangGraph Checkpointer SQL Injection to RCE Exposure

Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-24
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | LangGraph Checkpointer SQL Injection to RCE Exposure - Threat Intelligence Report

Published: 2026-06-24 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Actor / Campaign Overview
5. Tactics, Techniques, and Procedures
6. Infrastructure and Indicators
7. Victimology and Targeting
8. Detection Engineering
 - 8.1. Detection Summary
 - 8.2. Sigma / Detection Content
 - 8.3. Hunt Query
9. Threat Hunting
 - 9.1. Hunt Hypothesis
 - 9.2. Hunt Query
10. Risk Assessment
11. Recommended Actions
12. References

LangGraph Checkpointer SQL Injection to RCE Exposure

1. Executive Summary

Check Point Research described a vulnerability chain in LangGraph checkpointer components that can turn user-controlled filter input into SQL injection and unsafe deserialization paths. The report is relevant to defenders because self-hosted AI-agent infrastructure often holds API keys, workflow data, and downstream service credentials.

This report is written for SOC, vulnerability-management, and incident-response teams that need immediate huntable hypotheses rather than a passive news summary. It preserves source limitations where the public reporting does not provide raw IOCs.

2. Intelligence Requirements

Question	Current Answer	Confidence
What is the main defensive concern?	The campaign-risk pattern is exploitation of AI-agent framework components rather than a traditional malware family.	Medium
Are hard IOCs available from open sources?	Limited in this automated collection; prioritize behavior-based hunting and vendor IOC retrieval.	Medium
What telemetry should be reviewed first?	Endpoint process, identity, network, proxy, repository, and cloud/SaaS audit telemetry relevant to the campaign.	High

3. Source Review & Confidence

Source	Contribution	Confidence
Primary research article	Core campaign narrative and technical framing	High
Weekly intelligence/security news corroboration	Recency and prioritization context	Medium
Analyst synthesis	Defensive mapping and queries for local telemetry	Medium

4. Threat Actor / Campaign Overview

The campaign-risk pattern is exploitation of AI-agent framework components rather than a traditional malware family. Attackers that reach exposed self-hosted agent services may be able to turn application-layer input bugs into code execution and secrets access.

5. Tactics, Techniques, and Procedures

Tactic / Phase	Observed Technique	Evidence
Initial Access	Exploit public-facing application	Self-hosted AI agent endpoint or API receives malicious input.
Execution	Unsafe deserialization / RCE chain	Research describes SQLi chained into remote execution risk.

Credential Access	Secrets in AI-agent environment	Agent servers often hold model, database, and SaaS tokens.
-------------------	---------------------------------	--

6. Infrastructure and Indicators

Indicator / Infrastructure	Type	Operational Use
Public article source set	Source artifact	Use vendor reports as canonical IOC source when available.
Developer/reputation platforms, phishing pages, or public-facing services	Infrastructure class	Used to establish trust, deliver payloads, or reach exposed services.
Unusual outbound traffic after user interaction or server exploit	Behavioral observable	Hunt pivot when raw IOCs are absent or ephemeral.

7. Victimology and Targeting

Organizations self-hosting AI agents, developer platforms, automation services, and internal copilots are exposed if vulnerable components are reachable by untrusted users.

8. Detection Engineering

8.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
New process spawned by browser, script host, package manager, or service process	EDR process telemetry	Identify user-driven payload launch or server-side exploitation.
Suspicious repository/package/script retrieval	Proxy, DNS, endpoint network telemetry	Surface malware delivery, dependency abuse, or tool staging.
Credential or wallet access after lure execution	EDR/file/identity telemetry	Detect theft behavior and account compromise.

8.2. Sigma / Detection Content

```

title: Daily Threat Intel Behavioral Cluster - Suspicious Delivery And Credential Access
status: experimental
logsource:
  product: windows
  category: process_creation
detection:
  selection_parent:
    ParentImage|endswith:
      - '\chrome.exe'
      - '\msedge.exe'
      - '\firefox.exe'
      - '\node.exe'
      - '\python.exe'
      - '\w3wp.exe'
  selection_child:
    Image|endswith:
      - '\powershell.exe'
      - '\cmd.exe'
      - '\curl.exe'
      - '\wget.exe'
      - '\rundll32.exe'
      - '\regsvr32.exe'
condition: selection_parent and selection_child

```

```
fields:
- Image
- ParentImage
- CommandLine
- User
level: high
```

8.3. Hunt Query

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~
("chrome.exe", "msedge.exe", "firefox.exe", "node.exe", "python.exe", "w3wp.exe")
| where FileName in~ ("powershell.exe", "cmd.exe", "curl.exe", "wget.exe", "rundll32.exe", "regsvr32.exe")
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Count=count() by DeviceName,
InitiatingProcessFileName, FileName, ProcessCommandLine
| order by Count desc
```

9. Threat Hunting

9.1. Hunt Hypothesis

Campaign activity should produce a behavioral sequence: exposure to a lure or vulnerable interface, script/tool execution, network retrieval or callback, and credential/wallet/repository/cloud-secret access.

9.2. Hunt Query

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~
("powershell.exe", "cmd.exe", "node.exe", "python.exe", "git.exe", "npm.cmd", "pip.exe", "curl.exe", "wget.exe"
)
| where RemoteUrl has_any ("github", "gitlab", "paste", "raw", "api", "discord", "telegram", "wallet",
"crypto")
| summarize Connections=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName,
InitiatingProcessFileName, RemoteUrl, RemoteIP
| order by Connections desc
```

10. Risk Assessment

Factor	Assessment
Likelihood	Medium to high where the relevant technology, user population, or exposed service exists.
Impact	Credential theft, remote execution, data exposure, or security-control compromise depending on campaign.
Detection posture	Behavior-based hunts are required because public reporting may not include durable IOCs.

11. Recommended Actions

Priority	Owner	Action
Critical	SOC	Run the embedded KQL hunts against the last 30 days and escalate confirmed sequences.
High	Threat Intel	Pull vendor-provided IOCs from primary sources and merge into SIEM/EDR watchlists.

High	Engineering	Reduce exposed attack surface or risky user workflows tied to the campaign.
Medium	Awareness / AppSec	Alert targeted user groups or code owners on lure patterns and dependency risks.

12. References

- [1] Check Point: From SQLi to RCE - Exploiting LangGraph checkpointer — <https://research.checkpoint.com/2026/from-sqli-to-rce-exploiting-langgraphs-checkpointer/>
- [2] The Hacker News: LangGraph flaw chain — <https://thehackernews.com/2026/06/langgraph-flaw-chain-exposes-self.html>
- [3] VentureBeat: Langflow/LangGraph/LangChain exposure context — <https://venturebeat.com/security/7000-langflow-servers-under-attack-langgraph-langchain-same-holes>